



MEETUPS

Patras, Greece

Meetup #1

- Introduction.

Nikolas Filippatos

Cybersecurity Research Associate, University of Patras, ISSG

github.com/nikolasfil

linkedin.com/in/nikolas-filippatos



Supported By

HackTheBox



ISSG

Information Systems Security Group, University of Patras



Powerpoint Presentation.

CybersecurityWiki

github.com/nikolasfil/Cybersecurity-Wiki/wiki/meetup-01-introduction



Agenda.

- **Intros:** Introduction to Cybersecurity and CTFs.
- **Demos:** Showcasing CTF and Machines .
- **CSCG:** Cybersecurity Challenge Greece .
- **Hack-along:** Interactive Session on the dedicated labs.



- Intros.



Intro to Hacking.

Quotes

"Hacking is the art of exploiting weaknesses in a system to achieve a goal."

Jon Erickson, Hacking: The Art of Exploitation

"A hacker is someone who enjoys exploring the details of programmable systems and stretching their capabilities"

Charlie Miller, The Hacker's Handbook Series

Phases

- **Reconnaissance**: gathering information.
- **Initial Access - Execution**: initial foothold in the target system
- **Persistence**: maintaining access in a compromised system
- **Post Exploitation - Privilege Escalation**: obtaining admin rights
- **Discovery - Lateral Movement**: explore the compromised network



Intro to Capture The Flag.

Explanation

CTF stands for Capture The Flag, which is a type of cybersecurity competition where participants find and exploit vulnerabilities in systems to capture hidden "flags" or pieces of information. These competitions help develop and test cybersecurity skills in a gamified environment.

Categories

- **Cryptography:** Challenges involving encryption, hashing, and encoded data. The goal is usually to decode, decrypt, or analyze cryptographic systems to recover hidden information.
- **Web:** Focuses on vulnerabilities in web applications such as authentication flaws, SQL injection, XSS, and misconfigurations.
- **Reverse Engineering:** Involves analyzing compiled programs or binaries to understand how they work
- **Forensics:** Challenges based on analyzing digital artifacts such as network captures, disk images, logs, or memory dumps
- **Miscellaneous:** A broad category that includes puzzles or challenges that don't fit into other categories
- **Pwn:** Challenges focused on exploiting vulnerabilities in compiled programs.



Useful Linux Commands.

Generic Commands

ls	list files
cd	change directory
pwd	show current location
cat	print file
less	view large files
cp	copy files
mv	move / rename
rm	delete
man	help

Useful in Hacking

grep	find secrets
find	locate sensitive files
ps	inspect processes
ss	discover open ports
curl	attack web services
chmod	change permissions
history	find credentials
python3	scripting & payloads
whoami	information about user



- Tools.



nmap.

Description

Network Mapper is a network scanning tool used to discover hosts, open ports, running services, and operating systems on a network..

Common Uses

- Discover Live hosts
- Identify open ports
- Detect services and versions
- OS fingerprinting.

```
- Check if an IP address is up, and guess the remote hosts operating system:
nmap -O ip_or_hostname

- Try to determine whether the specified hosts are up (ping scan) and what their
names and MAC addresses are:
sudo nmap -sn ip_or_hostname optional_another_address

- Also enable scripts, service detection, OS fingerprinting and traceroute:
nmap -A address_or_addresses

- Scan a specific list of ports (use '-p-' for all ports from 1 to 65535):
nmap -p port1,port2,...,portN address_or_addresses

- Perform service and version detection of the top 1000 ports using default NSE
scripts; writing results ('-oN') to output file:
nmap -sC -sV -oN top-1000-ports.txt address_or_addresses

- Scan target(s) carefully using 'default and safe' NSE scripts:
nmap --script "default and safe" address_or_addresses

- Scan web server running on standard ports 80 and 443 using all available 'http-
*' NSE scripts:
nmap --script "http-*" address_or_addresses -p 80,443

- Perform a stealthy very slow scan ('-T0') trying to avoid detection by IDS/IPS
and use decoy ('-D') source IP addresses:
nmap -T0 -D decoy1_ipaddress,decoy2_ipaddress,...,decoyN_ipaddress
```



gobuster.

Description

Gobuster is a tool for brute forcing directories, DNS subdomains, and virtual hosts written in go..

Common Uses

- directory enumeration
- dns subdomain enumeration
- fuzzing
- s3 aws bucket enumeration
- tftp enumeration
- vhost enumeration

```
- Discover directories and files that match in the wordlist:
gobuster dir --url https://example.com/ --wordlist path/to/file

- Discover subdomains:
gobuster dns --domain example.com --wordlist path/to/file

- Discover Amazon S3 buckets:
gobuster s3 --wordlist path/to/file

- Discover other virtual hosts on the server:
gobuster vhost --url https://example.com/ --wordlist path/to/file

- Fuzz the value of a parameter:
gobuster fuzz --url https://example.com/?parameter=FUZZ --wordlist
path/to/file

- Fuzz the name of a parameter:
gobuster fuzz --url https://example.com/?FUZZ=value --wordlist path/to/file
```



ffuf.

Description

ffuf is a fast web fuzzer written in Go that allows typical directory discovery, virtual host discovery (without DNS records) and GET and POST parameter fuzzing.

Common Uses

- directory enumeration
- dns subdomain enumeration
- fuzzing
- s3 aws bucket enumeration
- tftp enumeration
- vhost enumeration

```
- Enumerate directories using [c]olored output and a [w]ordlist specifying a target [u]RL:
ffuf -c -w path/to/wordlist.txt -u https://example.com/FUZZ

- Enumerate webserver of subdomains by changing the position of the keyword:
ffuf -w path/to/subdomains.txt -u https://FUZZ.example.com

~ - Fuzz with specified [t]hreads (default: 40) and pro[x]ing the traffic and save [o]utput to a file:
ffuf -o -w path/to/wordlist.txt -u https://example.com/FUZZ -t 500 -x http://127.0.0.1:8080

- Fuzz a specific [H]eader ("Name: Value") and [m]atch HTTP status [c]odes:
ffuf -w path/to/wordlist.txt -u https://example.com -H "Host: FUZZ" -mc 200

- Fuzz with specified HTTP method and [d]ata, while [f]iltering out specific status [c]odes and response [s]ize:
ffuf -w path/to/postdata.txt -X POST -d "username=admin&password=FUZZ" -u https://example.com/login.php -fc 302,401-499 -fs 1234

- Fuzz multiple positions with multiple wordlists using different modes and [a]uto [c]alibration to reduce false positives:
ffuf -w path/to/keys:KEY -w path/to/values:VALUE -mode pitchfork|clusterbomb -u https://example.com/id?KEY=VALUE -ac

- Proxy requests through a HTTP MITM pro[x]y (such as Burp Suite or mitmproxy):
ffuf -w path/to/wordlist -x http://127.0.0.1:8080 -u https://example.com/FUZZ
```



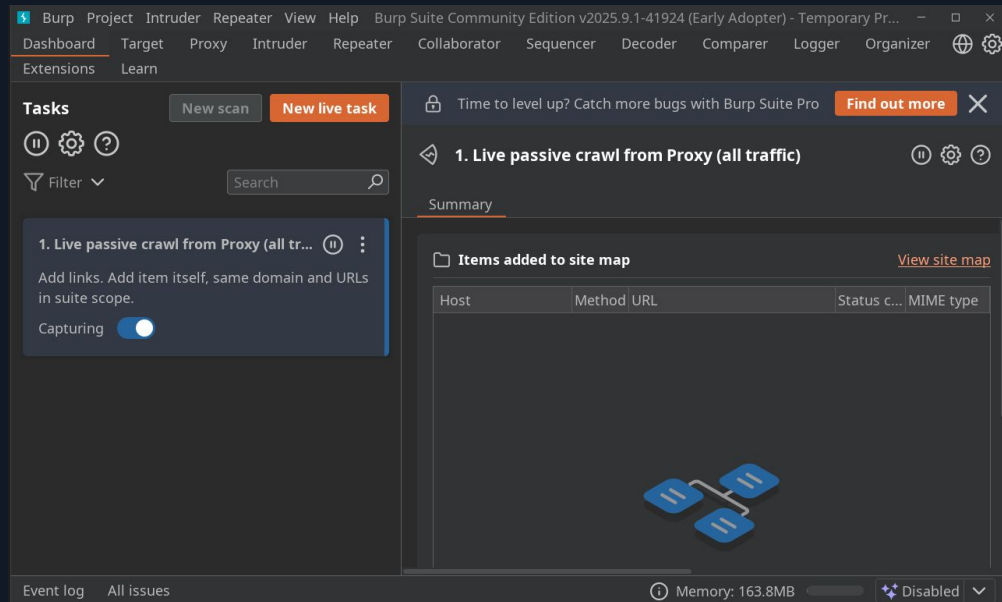
burpsuite.

Description

Burp Suite is a web security testing platform used for intercepting, modifying, and analyzing HTTP traffic.

Common Uses

- Intercept web traffic
- Modify requests
- Test authentication flows
- Find vulnerabilities



sqlmap.

Description

sqlmap is an automated tool used to detect and exploit SQL injection vulnerabilities.

Common Uses

- Detect SQL injection
- Dump databases
- Extract credentials
- Automated exploitation

Detect and exploit SQL injection flaws.

More information: <https://github.com/sqlmapproject/sqlmap/wiki/Usage>.

- Run sqlmap against a single target URL:

```
python sqlmap.py --url "http://www.example.com/vuln.php?id=1"
```

- Send data in a POST request (--data implies POST request):

```
python sqlmap.py --url "http://www.example.com/vuln.php" --data="id=1"
```

- Change the parameter delimiter (& is the default):

```
python sqlmap.py --url "http://www.example.com/vuln.php" --data="query=foobar;id=1" --param-del=";"
```

- Select a random User-Agent from ./txt/user-agents.txt and use it:

```
python sqlmap.py --url "http://www.example.com/vuln.php" --random-agent
```

- Provide user credentials for HTTP protocol authentication:

```
python sqlmap.py --url "http://www.example.com/vuln.php" --auth-type Basic --auth-cred "testuser:testpass"
```



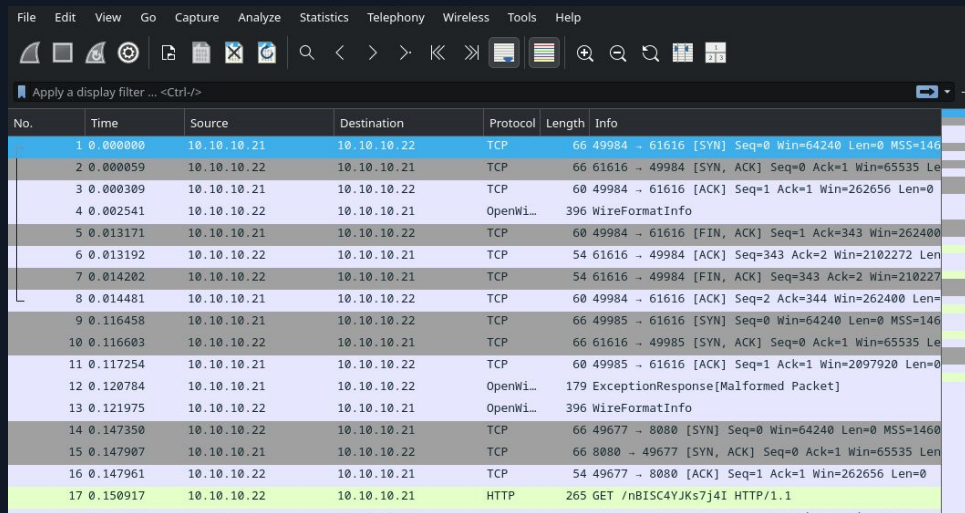
wireshark.

Description

wireshark is a network protocol analyzer used to inspect and analyze network traffic.

Common Uses

- Packet inspection
- Credential discovery
- Protocol analysis
- Traffic investigation



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.10.10.21	10.10.10.22	TCP	66	49984 → 61616 [SYN] Seq=0 Win=64240 Len=0 MSS=1460
2	0.000059	10.10.10.22	10.10.10.21	TCP	66	61616 → 49984 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0
3	0.000309	10.10.10.21	10.10.10.22	TCP	60	49984 → 61616 [ACK] Seq=1 Ack=1 Win=262656 Len=0
4	0.002541	10.10.10.22	10.10.10.21	OpenWi...	396	WireFormatInfo
5	0.013171	10.10.10.21	10.10.10.22	TCP	60	49984 → 61616 [FIN, ACK] Seq=1 Ack=343 Win=262400 Len=0
6	0.013192	10.10.10.22	10.10.10.21	TCP	54	61616 → 49984 [ACK] Seq=343 Ack=2 Win=2102272 Len=0
7	0.014202	10.10.10.22	10.10.10.21	TCP	54	61616 → 49984 [FIN, ACK] Seq=343 Ack=2 Win=2102272 Len=0
8	0.014481	10.10.10.21	10.10.10.22	TCP	60	49984 → 61616 [ACK] Seq=2 Ack=344 Win=262400 Len=0
9	0.116458	10.10.10.21	10.10.10.22	TCP	66	49985 → 61616 [SYN] Seq=0 Win=64240 Len=0 MSS=1460
10	0.116603	10.10.10.22	10.10.10.21	TCP	66	61616 → 49985 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0
11	0.117254	10.10.10.21	10.10.10.22	TCP	60	49985 → 61616 [ACK] Seq=1 Ack=1 Win=2097920 Len=0
12	0.120784	10.10.10.21	10.10.10.22	OpenWi...	179	ExceptionResponse[Malformed Packet]
13	0.121975	10.10.10.22	10.10.10.21	OpenWi...	396	WireFormatInfo
14	0.147350	10.10.10.22	10.10.10.21	TCP	66	49677 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460
15	0.147907	10.10.10.21	10.10.10.22	TCP	66	8080 → 49677 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0
16	0.147961	10.10.10.22	10.10.10.21	TCP	54	49677 → 8080 [ACK] Seq=1 Ack=1 Win=262656 Len=0
17	0.150917	10.10.10.22	10.10.10.21	HTTP	265	GET /nBISC4YJKs7j41 HTTP/1.1



Other useful tools

- **cyberchef**: web-based tool used for data analysis, encoding, decoding, encryption and transformation
- **ghidra**: reverse engineering framework developed by the NSA, used to analyze compiled binaries
- **metasploit**: penetration testing platform used to develop, test and execute exploits against vulnerable systems
- **revshells.com**: site useful for building a reverse shell command
- **pwncat**: a more advanced reverse shell
- **linpeas**: privilege escalation auditing tool for linux systems
- **pwntools**: python library used in exploitation
- **gdb**: debugger, useful for reverse engineering challenges, pwn, binary
- **wordlists**: <https://github.com/kkrypt0nn/wordlists>
- **pentestmonkey**: <https://pentestmonkey.net>



- CSCG.



Greece Cybersecurity Challenge.

Info

13th of March, University of
Peloponnese

Cyber security event for students in
Greece. A scenario-based game
played by teams of maximum 4



REGISTER
NOW!



cybersecuritychallenge.gr

SANS ON-DEMAND COURSES

For each member of the
winning team, **SANS
Institute** gives out 1 On-
Demand Course for any
SANS course of your choice.

CISCO CERTIFIED NETWORK ASSOCIATE COURSE & LPI SECURITY ESSENTIALS CERTIFICATION VOUCHER

For each member of the
second ranked team, **SCP
School of Certified
Professionals** offers a CCNA

SILVER ANNUAL ACADEMY & FORTINET ACCESS POINT

For each member of the
third ranked team,
HackTheBox gives out 1
Silver Annual Academy
subscription and **GCC
Hellas** gives out 1 Fortinet
Access Point.

VIP+ ANNUAL LAB SUBSCRIPTION

For each member of the
fourth ranked team,
HackTheBox gives out 1
VIP+ Annual subscription.

3-MONTH PROLAB SUBSCRIPTION

For each member of the
fifth ranked team,
HackTheBox gives out a 3-
month Prolab subscription



Looking for a team.

Google Form

If you are looking for a team or are looking to add members in your group

<https://forms.gle/BvviaPTRTR9TfjpL9>



- CTF.



CTF Challenges.

CryptOfTheUndead

Very Easy.

ReverseEngineering

El Pipo

Very Easy

Pwn

Data Siege

Medium

Forensics



- Virtual Machines.



Easy Machines.

Build



easy

Oopsie



very easy

Soulmate



easy

CodePartTwo



easy

Broker



easy



Not Easy Machines.

Cache



medium

Ambassador



medium

Heal



medium

Developer



hard

Skyfall



insane

Carpediem



hard





HACKTHEBOX

MEETUPS

Patras, Greece

Thank you!

